

ResolvX

Business Continuity & Disaster Recovery Policy

Topic-Specific Policy - Continuity, Resilience & Disaster Recovery

POL-008 · v1.0 · 2026 · Internal : Restricted

Document Information

Policy ID	POL-008
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	VP Engineering
Approver	CISO
Review Cycle	Annual, or upon material infrastructure change
Next Review	Q3 2027
Frameworks	ISO 27001:2022 A5.29, A5.30, A8.14 · NIST CSF 2.0 RC.RP-01/03, RC.CO-03 · SOC 2 A1.2, A1.3

1. Purpose

This Business Continuity & Disaster Recovery (BCP/DR) Policy establishes ResolvX's approach to maintaining or rapidly restoring critical business functions and systems in the event of a significant disruption whether from infrastructure failure, natural disaster, cyberattack, or loss of a critical third party.

A documented BCP/DR capability gives ResolvX confidence that critical business functions can be restored within defined timeframes following a disruption, and gives clients, regulators, and auditors assurance that continuity planning is a formalised, tested discipline. This policy, together with its accompanying recovery strategy, satisfies ResolvX's obligations under ISO 27001:2022 A5.29 (Information security during disruption) and A5.30 (ICT readiness for business continuity).

ResolvX processes dispute-resolution workflows on behalf of regulated financial institutions. An extended, undeclared, or poorly managed outage carries regulatory, contractual, and reputational consequences beyond the direct operational cost of downtime.

2. Scope

This policy applies to:

- All production AWS infrastructure (VPC, EC2, EKS, RDS, S3, IAM, Secrets Manager, CloudFront/API Gateway).
- Critical third-party dependencies (Okta, GitHub, Google Workspace) to the extent their unavailability impairs ResolvX operations.
- All personnel with a defined role in continuity or disaster recovery activation, response, or communication.

This policy does not replace the Incident Response Plan; the two are linked per §6.

3. Business Impact Analysis (BIA)

Recovery priority is driven by the criticality tiers already established in ResolvX's technology asset inventory. The table below defines target recovery objectives per tier.

Criticality Tier	Representative Assets	RTO	RPO
Critical	Production VPC, RDS database cluster, IAM/SSO, Secrets Manager	4 hours	15 minutes
High	S3 object storage, CDN/API Gateway, CloudWatch/CloudTrail logging	8 hours	1 hour
Medium	Staging environment	24 hours	24 hours
Low	Development environment	72 hours	Best effort

These targets are intentionally aligned with the Critical Services / Full Restoration RTO figures already defined in the Incident Response Plan's severity model, so that a P1/P2 security incident and a BCP/DR activation are measured against the same recovery clock rather than two competing standards.

4. Disaster Recovery Strategy

4.1 Current State

Production infrastructure runs on AWS with redundancy at the compute and database layer. Backups are taken on a schedule defined in the Backup & Recovery Policy (POL-009). ResolvX does not currently operate a formally tested warm or hot standby environment in a separate AWS region.

4.2 Target State

The following capabilities are being built toward, owned by VP Engineering and Head of Cloud Ops jointly:

- Documented, versioned infrastructure-as-code sufficient to rebuild the production environment in a new region within the Critical-tier RTO.
- Cross-region backup replication for the RDS database cluster and S3 object storage.
- A documented failover runbook, tested at the cadence defined in §8.
- Defined dependency map showing which critical third parties (Okta, GitHub, Google Workspace) have no ResolvX-side failover and are tracked as accepted residual risk.

5. Activation

This plan is activated when a disruption is assessed to breach, or be likely to breach, the RTO for a Critical or High tier asset. Activation may originate from:

- Escalation of a P1 or P2 security incident under the Incident Response Plan where recovery, not just containment, is required.
- Direct infrastructure failure or AWS regional service disruption not related to a security incident.
- Loss of access to a Tier 1 Critical third-party vendor (see POL-005 / TPRM register) with no available workaround.

VP Engineering, in consultation with the CISO, has authority to formally declare BCP/DR activation. The CEO is notified immediately upon activation for any Critical-tier asset.

If VP Engineering is unreachable within 30 minutes of a suspected Critical-tier disruption, Head of Cloud Ops has standing authority to declare activation and begin recovery, notifying VP Engineering and the CISO as soon as they are reachable. Declaration authority does not wait on a single point of contact.

6. Relationship to the Incident Response Plan

Where a disruption originates from a security incident, the Incident Response Plan's severity model and escalation path governs detection, containment, and stakeholder notification. This BCP/DR Policy governs the parallel recovery workstream — restoring service within the RTO/RPO targets in §3 — once the incident is contained. The two run concurrently for a P1/P2 security-originated outage, with VP Engineering leading recovery and the CISO leading incident response.

7. Recovery Verification & Communication

7.1 Data Integrity After Recovery

Meeting the RTO alone is not sufficient, restored systems must also be verified as functionally correct before being declared recovered. VP Engineering confirms application-level functional checks pass, and Head of Cloud Ops confirms data integrity checks (per POL-009 §6.3) before a Critical or High tier system is declared restored and the activation is stood down.

7.2 Out-of-Band Communication

Primary coordination channels (Slack, Google Workspace) may themselves be affected by a disruption, particularly one involving a broader cloud or identity provider outage. A phone-based bridge line and a pre-agreed backup messaging channel outside ResolvX's primary stack are maintained as a fallback, so activation and status communication does not depend entirely on the systems being recovered.

7.3 Post-Recovery Review

Every BCP/DR activation — whether a real disruption or a scheduled test — is followed by a review within 10 business days, comparing actual recovery time against the targets in §3, documenting any deviation, and feeding lessons learned into the next annual test in §8.

8. Testing & Exercises

The following testing cadence is established as of this policy's effective date:

Exercise	Frequency	Owner
Backup restoration test (Critical-tier data)	Quarterly	Head of Cloud Ops
Full DR failover tabletop exercise	Annual	VP Engineering
Combined IR + DR tabletop simulation	Annual (may combine with IR Plan's tabletop)	CISO / VP Engineering

Results of every test are documented and retained as audit evidence, and any failed recovery target is logged as a Corrective Action Plan (CAP) item.

9. Roles & Responsibilities

9.1 VP Engineering

- Owns this policy and the DR strategy (§4).
- Has authority to declare BCP/DR activation (§5).
- Leads recovery execution and reports recovery status to the CEO and CISO.

9.2 Head of Cloud Ops

- Executes technical recovery procedures against AWS infrastructure.
- Owns backup integrity and restoration testing (§8).

9.3 CISO

- Co-authorizes activation for incidents with a security origin.
- Ensures alignment between BCP/DR activation and the Incident Response Plan.

9.4 GRC Lead

- Maintains this policy and retains test evidence.
- Logs any missed RTO/RPO target as a CAP item.

10. Compliance and Enforcement

Failure to execute a scheduled test under §8, or failure to follow the activation and escalation path in §5 during an actual disruption, is treated as a control deficiency and logged in the Corrective Action Plan.

11. Document Control

Policy ID	POL-008
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	VP Engineering
Approver	CISO
Review Cycle	Annual, or upon material infrastructure change
Next Review	Q3 2027
Framework References	ISO/IEC 27001:2022 A5.29, A5.30, A8.14 · NIST CSF 2.0 RC.RP-01, RC.RP-03, RC.CO-03 · SOC 2 TSC A1.2, A1.3
Related Documents	POL-001 (Information Security Policy), POL-005 (Vendor Management), POL-007 (Logging & Monitoring), POL-009 (Backup & Recovery, pending), Incident Response Plan

ResolvX GRC Program — Internal Use Only — v1.0 — 2026

Authorisation

Role	Name	Date
CEO		
CISO		
GRC Lead		